JY Group 개인정보 진단 실습 보고서

문서ID: JY-FINAL-2026-10 작성일: 2026-10-07 본문 확장: 2026-10-19 수행자: 김준영 (고객 역할과 컨설턴트 역할을 겸함. 실제 고객 인터뷰가 아님) 대상: 로컬 Zammad 1식 http://127.0.0.1:8080 (JY Retail / Service / Vendor 상담) 브랜치: docs/closeout-deliverables-02 기준 커밋: 949a0bd 이 보고서는 가상 실습 결과다. 실제 기업 감사, 인증, 법률 자문, 법정 통지가 아니다. 가이드 PDF를 이 보고서 대신 제출하지 않는다. 확인하지 않은 조항은 충족으로 쓰지 않는다.

원본 증적 PNG와 JSON, 토큰은 Git에 없다. 보관 위치는 C:₩JY-Lab₩private-evidence₩다.

JY Group 개인정보 진단 실습 보고서 1

1. 표지 정보 2

2. 문서 통제표 2

3. 경영진 요약 2

4. 배경과 목적 3

5. 범위·제외·가정 3

6. 조직과 처리 관계 3

7. 환경과 버전 3

8. 방법론과 판정 규칙 4

9. 법령·ISMS-P·ISO·기술 참고 4

10. 데이터 흐름 5

11. 24개 Checks 결과 5

12. F-01 상세 9

13. F-02a 상세 11

14. F-02b 상세 13

15. F-03 상세 14

16. 위험평가 15

17. 개선 Actions 16

18. 재점검 16

19. 잔여위험·예외·미확인 16

20. 30/90일 계획 17

21. 수행 한계 17

22. 출처 색인 17
23. 증적 색인 18
24. Git/CI/Release 검증 18

1. 표지 정보

항목	내용
프로젝트	JY그룹 개인정보 보호 컨설팅 실습
시스템	로컬 Zammad 1식
수행 기간	2026-10-06 시험. 문서는 2026-10-19까지 보완
버전	보완 초안. v1.0-final.1 태그는 없음
성격	가상 실습. 인증 발표가 아님

2. 문서 통제표

판	날짜	내용
초안	2026-10-07	요약 7절
보완	2026-10-19	24절. 워크북 시트 수와 현재 브랜치를 반영

이 판은 main에 머지하기 전이다. main 35b7b85의 태그 v1.0-final은 옮기지 않는다.

3. 경영진 요약

상담 티켓에 이름, 이메일, 문의, 첨부가 남는 흐름을 로컬 Zammad 한 대로 점검했다. Checks 24행의 결과는 적합 8, 미흡 13, 미확인 2, 적용 제외 1이다.

바로 고친 항목은 종료 계정 S05의 비활성, 과다 권한 회수, 조직 공유 해제다. 재점검 R-01, R-02a, R-02b는 적합이다. 처음 발견한 Checks 미흡은 재점검 적합으로 덮지 않았다.

현재 위험은 F-01, F-02a, F-02b가 각 6점·계획이고, F-03이 9점·우선이다. 세션 회수, 후 T11의 대상·순서, S06·S03 후 시험, 직접 주소·첨부 거부, 완료 화면, 백업 잔존처럼 발생이 미확인인 잔여에는 점수를 넣지 않는다.

필요한 결정은 T12를 Scheduler 미리보기 1건 없이 삭제하지 않는 것이다. A-03은 2026-10-06 기한이 지났고 미완료다. 새 목표일과 다음 검토일은 2026-11-06이다. 담당은 S02이고 실행은 S01이다. 추가 작업 시간과 자원 견적은 근거가 없어 적지 않는다. 보완통제는 T12와 로컬 사본을 증적으로 유지하는 것이다. 다음 보고일은 2026-11-06이다.

4. 배경과 목적

상담 시스템에서 목적 결정, 상담 수행, 유지보수 권한이 한 시스템에 모인다. 이번 실습의 목적은 그 범위에서 계정 회수, 최소권한, 파기 범위를 화면과 문서로 대조하는 것이다. 여러 서버로 범위를 넓히지 않았다.

5. 범위·제외·가정

포함: Retail의 상담 목적 결정, Service의 상담 수행, Vendor의 유지보수 권한. 시스템 1식.

제외: 결제, 배송, 마케팅, 백업 복구 실측, USB와 DLP, 웹 취약점 전수, 실제 메일 발송.

근거: 워크북 Scope, Checks A01 적합.

가정: 계정과 고객은 합성 자료다. 이메일은 .example.test만 사용한다. 수행자가 고객 역할과 컨설턴트 역할을 겸했다. 실제 고객 인터뷰는 없다.

6. 조직과 처리 관계

역할	계정	관계
S01	admin@jy.example.test	시스템 관리
S02	privacy@jy.example.test	문서상 개인정보 보호 담당
S03	lead@service.example.test	제한상담. Restricted 유지
S04	agent@service.example.test	일반상담. 조치 후 General만
S05	former@service.example.test	종료일 2026-09-14. 조치 후 Active=false
S06	maint@vendor.example.test	유지보수. 조치 후 그룹 없음

그룹은 JY-General과 JY-Restricted다. 조직 JY-Lab-Customers는 조치 후 공유가 '아니오'다. 과거 기록의 고객 수는 삭제 전 10명, C01 삭제 후 9명이다. 2026-10-20에 고객 수를 다시 실측하지 않았다.

7. 환경과 버전

자세한 관측일은 docs/environment.md에 있다.

항목	값	관측
Windows	Windows 11 Home, 버전 25H2, OS 빌드 26200.9711	2026-10-19
Git	2.54.0.windows.1	2026-10-08과 같음
Python	3.13.14	2026-10-08과 같음
Docker Engine	29.7.2	2026-10-08과 같음

Compose	v5.5.1	2026-10-08과 같음
Zammad compose commit	27944f87aed91420242dfa97038ff96555d7cbe7	2026-10-08과 같음
Zammad 이미지	ghcr.io/zammad/zammad:7.1.3-0011	2026-10-08과 2026-10-14. 2026-10-19에는 엔진이 중지되어 다시 확인하지 않음
화면 버전	7.1.3-ed9434c4.docker	2026-10-08 관리 영역
주소	http://127.0.0.1:8080	한국어 UI

docker compose down -v는 실행하지 않았다.

8. 방법론과 판정 규칙

판정은 적합, 미흡, 미확인, 적용 제외, 미실시다. 재점검이 적합이어도 처음의 Checks 미흡은 유지한다. 미확인과 적용 제외를 적합으로 올리지 않는다.

과거 v1 수집은 127.0.0.1:8080 GET만 사용하고 diff 서브커맨드가 없었다. 그때의 전후 비교는 동일 staff.csv, 동일 Zammad, 동일 직원 ID로 수동 검증했다. users-diff.json에는 S05 active True에서 False만 기록되어 있고, 그 파일은 private-evidence/after에만 둔다. 현재 도구는 v2의 collect, diff, verify다. v1 수동 비교와 v2 명령을 같은 절차로 적지 않는다. 자동화 전체 구현 완료로 쓰지 않는다.

tools/list_zammad.py는 http://127.0.0.1:8080과 http://localhost:8080만 허용한다. 프록시와 리다이렉트를 차단한다.

9. 법령·ISMS-P·ISO·기술 참고

출처	확인 범위	한계
개인정보 보호법 제21445호	시행 2026-09-11. 공포 2026-03-10	머리글과 대조한 조문
시행령 제36671호	시행 2026-09-11. 공포 2026-09-10	대조 조문은 제30조
안전성 확보조치 기준 고시 제2026-9호	시행 2026-07-01. 제5조 제1항·제2항·제4항의 계정 회수와 최소 권한	제4조, 제5조 제3항·제6항, 제6조는 미기입
ISMS-P 인증기준 안내서 (2023.11)	2023-11-23 수정게시. 2.5.1 87쪽, 2.6.3 105쪽, 3.4.1 240쪽	인증심사가 아님. 2.5.6 정기 검토는 하지 않음
ISO/IEC 27701:2025	2025-10-14 제2판. 공개 서지정보	본문 조항 미확인
KISA 주통기 기술 상세가이드	2025-12-24 게시	이번 실습의 직접 기술 범위가

아님

Checks A02 증적ID는 S-L01~S-L07이고 판정은 적합이다. 적용 범위는 위 표대로 구분한다.

Controls에 넣은 항·호는 법 제29조, 영 제30조 제1항 제2호, 법 제26조 제4항·제5항, 법 제21조 제1항·제2항이다. 이 문장은 위반 확정이 아니다.

10. 데이터 흐름

상담 목적과 문의, 첨부, 이름은 티켓에 남는다. 화면 흐름은 docs/data-flow.pdf에 있다. 다운로드 사본은 관측했다. 백업 보존과 복구는 미확인이다. Checks A03은 적합이고, 그 적합을 백업 실측으로 확대하지 않는다.

핵심 티켓: F-01의 T02는 #52020이고 내부ID는 미확인이다. #52003(id 3)은 S04 정상업무의 다른 티켓이다. T11 시험본은 29번 52028이고 삭제되었다. T12는 14번 52014이고 유지한다. T15는 17번 52017이고 보존한다. 복제 번호는 tickets.csv의 id_note에 둔다. T03부터 T10, T13, T14의 actual_id 공란은 추측해서 채우지 않는다.

11. 24개 Checks 결과

적합: A01 A02 A03 A04 B01 C01 E02 F01

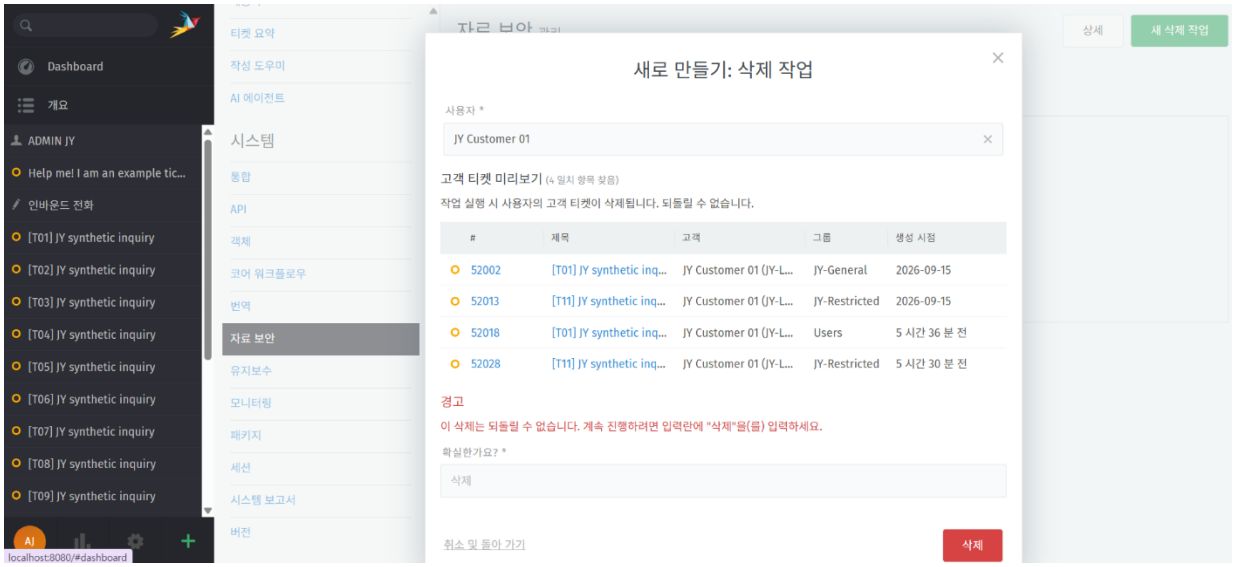
미흡: B02 B03 C02 C03 C04 D01 D02 D03 D04 E01 E03 F02 F04

미확인: B04 E04

적용 제외: F03

합계 24. 미실시 행은 없다.

워크북은 13시트다. 기본 11개에 Incident와 FinalReview가 있다. Checks E02의 증적ID는 E-F03-B01이다.



E-F03-B01. 공개 경로 evidence/sanitized/E-F03-B01.png. 관측 시각은 파일에 없다. F-03 삭제 전 화면. 완료 화면은 다시 보지 않았다.

초기 Checks 24행

이 표는 처음 판정이다. 재점검 적합으로 바꾸지 않는다.

Check	판정	내용
A01	적합	3조직 1시스템. 결제·배송·마케팅·백업 실측은 제외
A02	적합	출처 S-L01~S-L07. 판·시행일·확인일
A03	적합	논리 흐름은 docs/data-flow.pdf. 백업 실측은 아님
A04	적합	문서상 보호 담당은 S02. 시스템 Admin은 S01
B01	적합	상담 항목은 이름, 이메일, 문의, 첨부
B02	미흡	초기 처리방침의 보유·위탁·권리 문구가 불충분
B03	미흡	제3자 제공과 위탁의 구분이 빈약
B04	미확인	권리 요청의 실제 접수·본인확인·회신 메일이 없음
C01	적합	직원 6명. Admin은 S01
C02	미흡	종료 계정 S05의 회수. 기존 세션은 미확인
C03	미흡	S04·S06의 제한상담 T11 열람
C04	미흡	고객 조직 공유. 직접 주소 거부와는 별개
D01	미흡	제공 자료에서 수탁 계약 문서 미확인. 연간 실적 아님
D02	미흡	S06 상시 권한. 한시 양식은 있고 운영은 미실시
D03	미흡	로컬 사본 잔존. USB·DLP는 범위 밖
D04	미흡	교육 1장은 있음. 서명과 출석은 없음

E01	미흡	보유기간이 필요할 때까지로 모호. 기간 숫자는 만들지 않음
E02	적합	C01 본인 티켓 삭제 범위. 증적 ID는 E-F03-B01
E03	미흡	T12 참조와 사본 잔존. 백업은 E04
E04	미확인	백업 잔존과 복구는 미확인
F01	적합	증적 추적. 원본은 Git 밖
F02	미흡	사고 양식과 실제 신고를 구분. 이번 건의 72시간을 법정 기한으로 단정하지 않음
F03	적용 제외	외부 AI 미연결
F04	미흡	F-01·F-02 재점검과 F-03 잔존을 구분. 잔존을 완료로 올리지 않음

현재 FinalReview 24행

현재 판정은 초기 판정과 같다. 담당과 기한은 2026-10-20에 정한 잔여 조건이다. B02와 B03은 미흡으로 두고, 이 표에서 새 기한을 만들지 않는다.

Check	현재 판정	담당	기한	근거와 한계
A01	적합	S02	추가 기한 없음	범위 전제. 조항을 이 행에 새로 붙이지 않음
A02	적합	S02	추가 기한 없음	S-L01~S-L07. 조문 재독은 아님
A03	적합	S02	추가 기한 없음	흐름도 있음. 백업 실측은 아님
A04	적합	S02	추가 기한 없음	문서상 S02, Admin S01. 실제 서명은 미확인
B01	적합	S02	추가 기한 없음	수집 항목 4개. 전부 동의로 쓰지 않음
B02	미흡	S02	이 표에서 새로 정	After 문안이 있어도 초기 미흡은 유

			하지 않음	지
B03	미흡	S02	이 표에서 새로 정하지 않음	제공과 위탁 구분 부족. 그룹사 명칭은 근거가 아님
B04	미확인	S02	2026-11-06	JY-RR-2026-01은 모의 기록. 실제 발송은 없음
C01	적합	S01	추가 기한 없음	계정 6개. 인증심사는 아님
C02	미흡	실행 S01, 기록 S02	즉시 2026-10-06 완료. 근본 2026-11-06	새 로그인 차단만 확인. 기존 세션은 미확인. 잔여 점수 없음
C03	미흡	실행 S01, 기록 S02	즉시 2026-10-06 완료. 근본 2026-11-06	후 T11의 대상·순서와 S06·S03 후 시험은 미확인. 잔여 점수 없음
C04	미흡	실행 S01, 기록 S02	즉시 2026-10-06 완료. 근본 2026-11-06	목록 숨김만 확인. 직접 주소와 첨부 거부는 미확인. 잔여 점수 없음
D01	미흡	S02	2026-11-06	제공 자료에서 계약 문서 미확인. 연간 실적은 아님
D02	미흡	실행 S01, 기록 S02	2026-11-06	한시 양식은 있음. 운영 미실시. E-F02-B02는 조치 전 증적
D03	미흡	S02	2026-11-06	jy-doc02-copy.txt 잔존. 화면 삭제로 PC 사본은 지워지지 않음
D04	미흡	S02	2026-11-06	교육 1쪽 PDF는 있음. 서명·출석·수료는 없음
E01	미흡	S02	2026-11-06	보유 판단이 모호.

				기간 숫자는 만들지 않음
E02	적합	S01	추가 기한 없음	본인 티켓 삭제. 참조 잔존은 E03
E03	미흡	담당 S02, 실행 S01	2026-10-06 경과. 새 목표 2026-11-06	A-03 미완료. T12는 미리보기 없이 삭제하지 않음. 완료 화면은 다시 보지 않음
E04	미확인	S02	2026-11-06	백업 잔존·복구 미확인. 이 범위에 점수를 넣지 않음
F01	적합	S02	추가 기한 없음	해시와 합성 명부. 원본 PNG·JSON은 private-evidence
F02	미흡	S02	2026-11-06	도상훈련과 실제 신고를 구분. 미확인 사고에 72시간을 단정하지 않음
F03	적용 제외	S02	추가 기한 없음	외부 AI 미연결. 연결하는 변경이 생기면 별도 검토
F04	미흡	S02	2026-11-06	재점검 적합과 F-03 잔존을 한 상태로 합치지 않음

12. F-01 상세

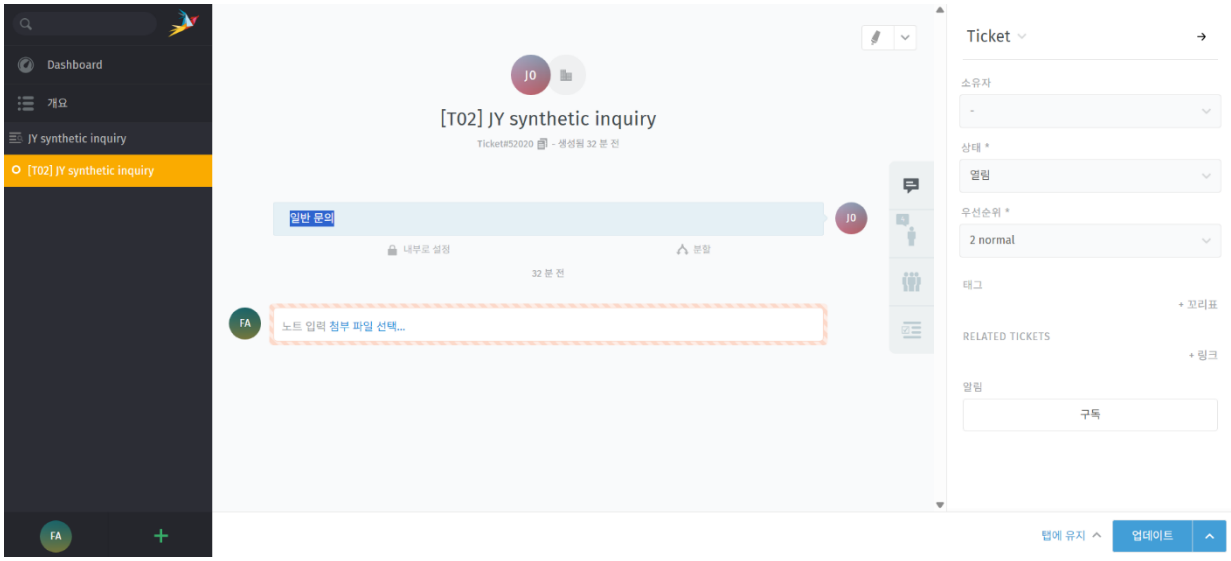
대상: 종료 계정 S05. 열람 대상은 T02 #52020이다. 내부ID는 미확인이다. #52003(id 3)은 S04 정상업무의 다른 티켓이다.

시험 조건: 종료일 2026-09-14 이후 Active 상태. T02 #52020 열람. #52003(id 3)은 이 시험의 대상이 아니다.

재현 절차: 종료 계정으로 일반상담 티켓 열람을 확인하고, Active를 false로 바꾼 뒤 새 로그인을 확인했다.

관측 결과: 종료 후에도 계정이 활성이었고 T02 #52020을 열람했다. 조치 후 새 로그인은 차단되었다. 로그인 후 캡처만으로 입력 계정을 특정하지는 못했다. 기존 세션과 외부 토큰 회수는 미확인이다.

전 증적: E-F01-B01, JSON-F01-B.



E-F01-B01. 공개 경로 evidence/sanitized/E-F01-B01.png. 관측 시각은 파일에 없다. F-01 조치 전 화면. 입력 계정 특정과 기존 세션은 이 화면 밖이다.

원인: 종료일 이후 계정 회수가 늦었다.

업무 영향: 발생 3, 영향 2, 점수 6, 계획. 조치 후 잔여는 발생이 미확인이라 점수를 넣지 않는다.

적용 기준: 법 제29조, 영 제30조 제1항 제2호 가목. ISMS-P 2.5.1 참고. 인증심사가 아니다.

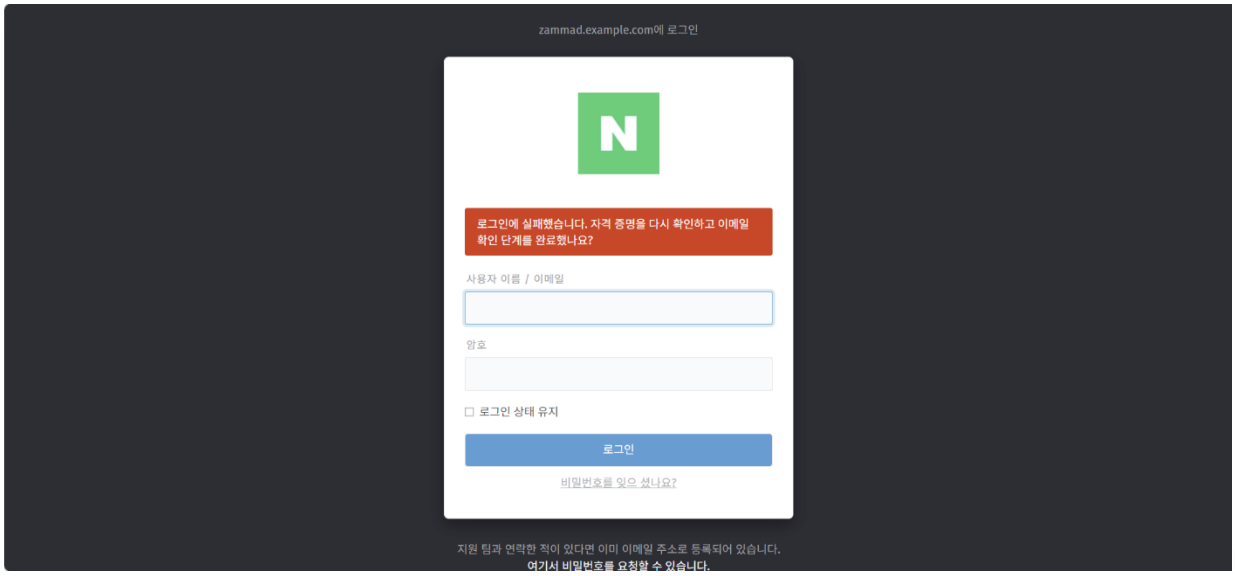
즉시조치: A-01. Active=false. 완료일 2026-10-06. 실행 S01.

근본조치: 종료 계정 점검 반복은 90일 계획에 남아 있다. 이번 실습에서 반복 운영은 하지 않았다.

후 증적: E-F01-A01, JSON-F01-A, JSON-F01-DIFF. diff에는 S05 active True에서 False만 있다.

공개 요약 evidence/sanitized/users-active.csv. 바뀐 값은 S05의 active뿐이다. 세션과 권한은 이 표에 없다.

직원ID	active_before	active_after
S01	true	true
S02	true	true
S03	true	true
S04	true	true
S05	true	false
S06	true	true



E-F01-A01. 공개 경로 evidence/sanitized/E-F01-A01.png. 관측 시각은 파일에 없다. F-01 조치 후 화면. 새 로그인 차단만 보여 주고 기존 세션 회수는 확인하지 않는다.

정상업무 검증: 재점검 R-01 적합.

잔여위험: 기존 Sessions 회수는 미확인. Checks C02는 미흡이다. 이 잔여에는 점수를 넣지 않는다.

현재 상태: 조치와 재점검은 완료. C02 미흡과 EX-02는 유지.

13. F-02a 상세

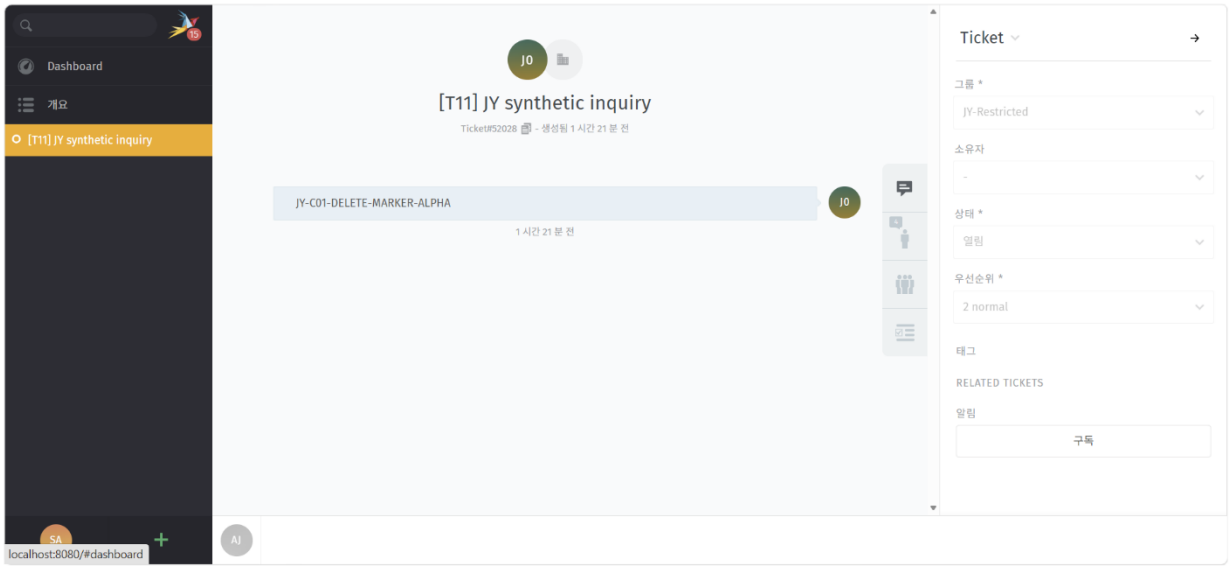
대상: S04, S06의 제한상담 열람.

시험 조건: 제한상담 T11 29번 52028.

재현 절차: 일반상담 계정과 유지보수 계정의 그룹을 확인하고, 제한 티켓 열람 여부를 본 뒤 그룹을 조정했다.

관측 결과: S04와 S06이 T11을 열람했다. 조치 후 S04는 JY-General만, S06의 그룹은 비었다. 후 T11의 대상과 회수 순서는 미확인이다. S06 차단 후 시험과 S03 후 시험은 미확인이다.

전 증적: E-F02-B01, E-F02-B02. E-F02-B02는 S06의 조치 전 증적이다.



E-F02-

B01. 공개 경로 evidence/sanitized/E-F02-B01.png. 관측 시각은 파일에 없다. F-02 조치 전 화면. 후 T11의 대상과 순서는 이 화면 밖이다.

원인: 업무에 필요한 범위를 넘는 그룹 소속.

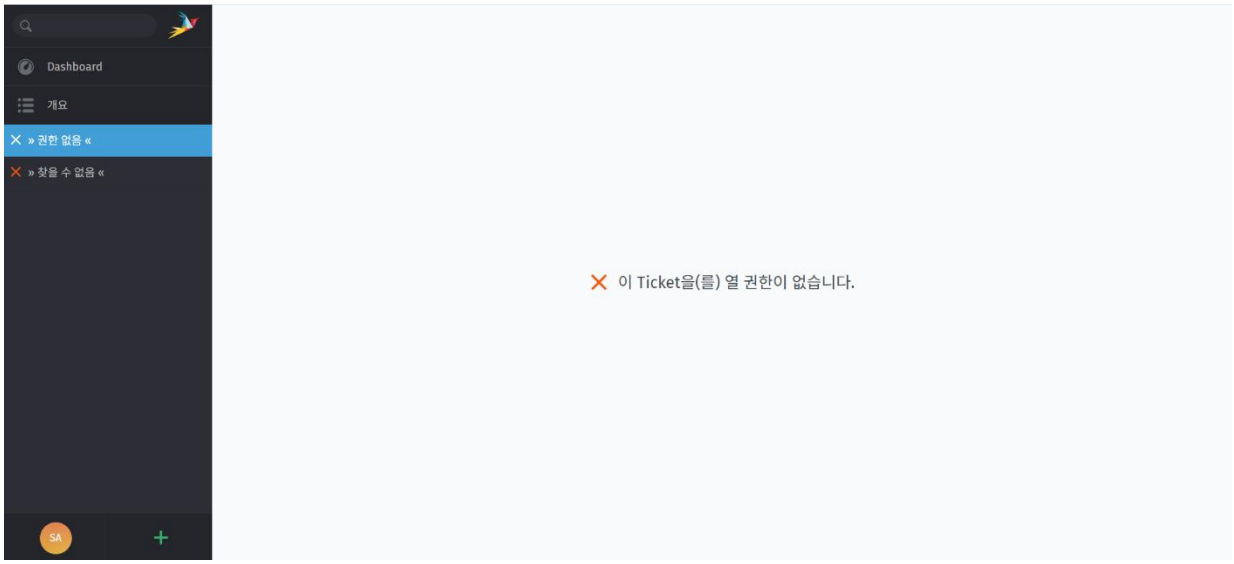
업무 영향: 발생 3, 영향 2, 점수 6, 계획. 대상은 일부 고객 상담이다. 조치 후 잔여는 발생이 미확인이라 점수를 넣지 않는다.

적용 기준: 법 제29조, 영 제30조 제1항 제2호. ISMS-P 2.5.1의 최소권한 참고. 2.5.6 정기 검토는 하지 않았다.

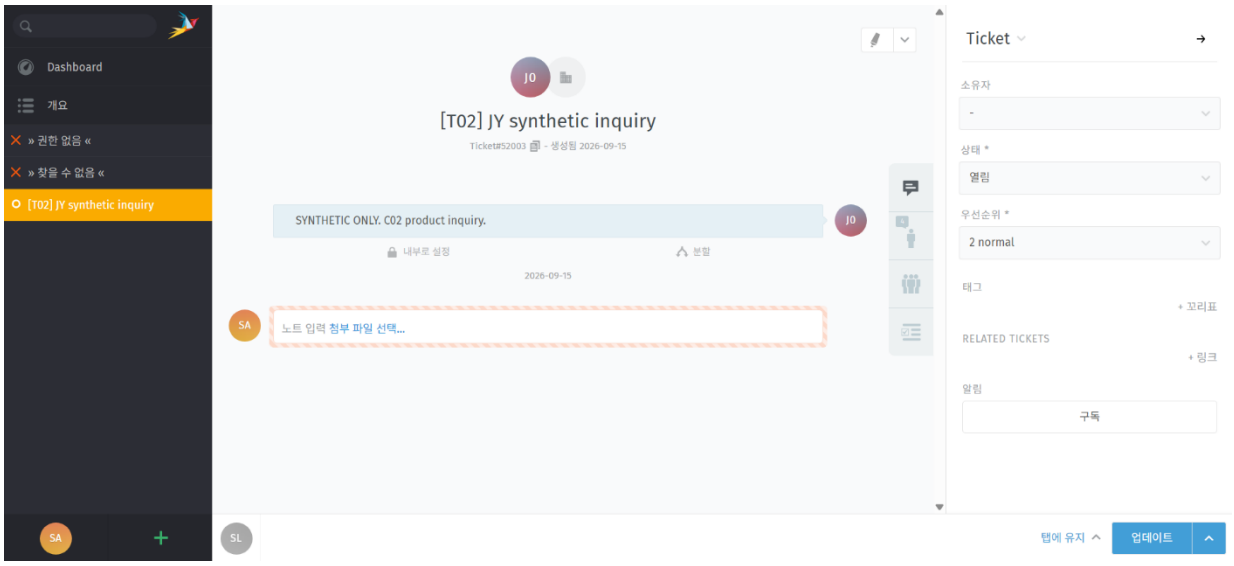
즉시조치: A-02a. S04는 General만. S06은 그룹 없음. S03 Restricted full은 유지. 완료일 2026-10-06. 실행 S01.

근본조치: 수탁 권한 재확인은 90일 계획이며 이번 실습의 연간 실적은 없다. 다음 기한은 2026-11-06이다.

후 증적: E-F02-A01, E-F02-A01b, E-F02-A02. 이 증적으로 후 T11의 대상과 순서가 확인되지는 않는다.



E-F02-A01. 공개 경로 evidence/sanitized/E-F02-A01.png. 관측 시각은 파일에 없다. F-02 조치 후 화면. S06 차단 후 T11 시험은 이 화면으로 확인하지 않는다.



E-F02-

A02. 공개 경로 evidence/sanitized/E-F02-A02.png. 관측 시각은 파일에 없다. F-02 조치 후 화면. 직접 주소와 첨부 거부는 이 화면 밖이다.

정상업무 검증: 재점검 R-02a 적합.

잔여위험: 다운로드 사본은 권한 회수만으로 지워지지 않는다. Checks C03과 D02는 미흡이다. 잔여 점수는 넣지 않는다.

현재 상태: 조치와 재점검은 완료. C03과 D02 미흡은 유지.

14. F-02b 상세

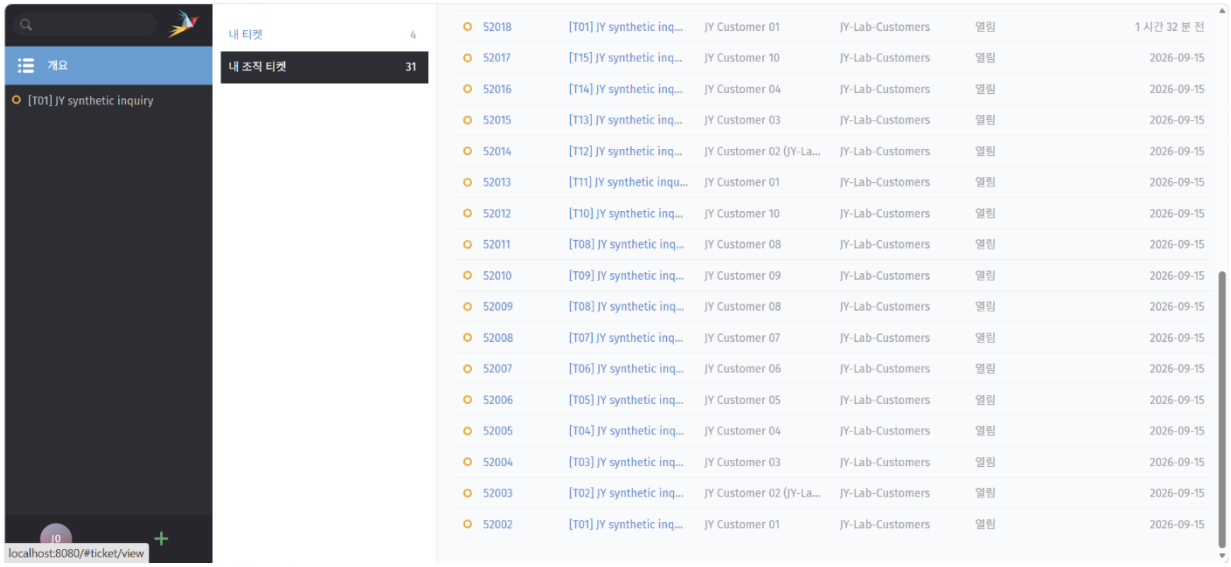
대상: 조직 공유를 통한 C01 티켓 열람.

시험 조건: C02가 공유 조직에서 C01의 T01을 열람.

재현 절차: 조직 공유 값을 확인하고, 공유를 아니오로 바꾼 뒤 열람 범위를 다시 보았다.

관측 결과: 공유가 허용된 동안 다른 고객 쪽 계정에서 T01을 볼 수 있었다. 조치 후 확인한 것은 목록 숨김이다. 직접 T01 주소와 첨부 거부는 미확인이다.

전 증적: E-F02-B03.



E-F02-B03. 공개 경로 evidence/sanitized/E-F02-B03.png. 관측 시각은 파일에 없다. F-02b 조치 전 조직 공유 화면.

원인: JY-Lab-Customers 공유가 예였다.

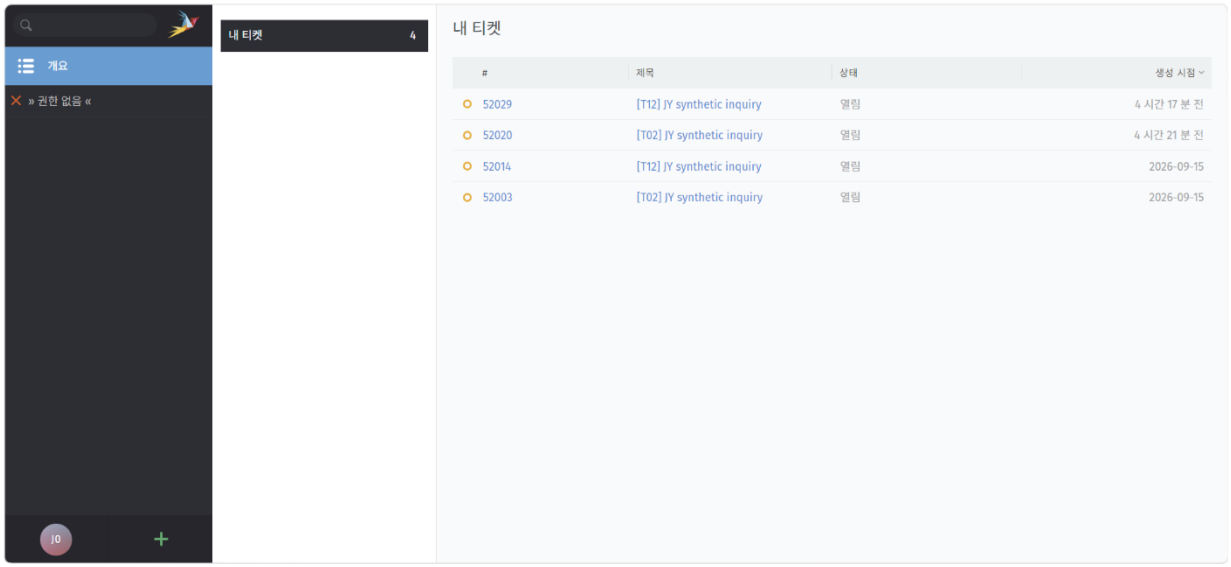
업무 영향: 발생 3, 영향 2, 점수 6, 계획. 조치 후 잔여는 발생이 미확인이라 점수를 넣지 않는다.

적용 기준: 법 제26조 제4항·제5항, 법 제17조·제18조의 목적 외 제공 구분. 그룹사 명칭만으로 제공 근거가 되지 않는다.

즉시조치: A-02b. 공유=아니오. 완료일 2026-10-06. 실행 S01.

근본조치: 위탁과 제3자 제공의 문서 구분은 초기 자료에서 부족하다. Checks B03은 미흡이다. 다음 기한은 2026-11-06이다.

후 증적: E-F02-A03.



E-F02-A03. 공개 경로 evidence/sanitized/E-F02-A03.png. 관측 시각은 파일에 없다. F-02b 조치 후 목록 화면. 직접 주소와 첨부 거부는 미확인이다.

정상업무 검증: 재점검 R-02b 적합.

잔여위험: Checks C04는 미흡이다. 연간 수탁 실적은 없다. 직접 주소와 첨부 거부는 미확인이라 잔여 점수를 넣지 않는다.

현재 상태: 시스템 공유는 해제. C04와 D01 미흡은 유지.

15. F-03 상세

대상: C01 삭제 요청에 해당하는 본인 티켓과 그 밖의 잔존.

시험 조건: 합성 계정 C01. 실제 고객 요청과 실제 메일은 없다.

재현 절차: 자료 보안 미리보기로 본인 티켓을 확인한 뒤 C01, T01, T11을 삭제하고, T12와 T15, 로컬 사본을 다시 확인했다.

관측 결과: 본인 티켓 T01과 T11은 삭제되었다. T12 14번 52014에 삭제 마커가 남았다. 로컬 사본 jy-doc02-copy.txt가 남았다. T15 17번 52017은 보존되었다.

전 증적: E-F03-B01, E-F03-B02, E-F03-B03.

원인: 삭제 버튼이 참조 티켓, 로컬 사본, 백업까지 지우지 않는다.

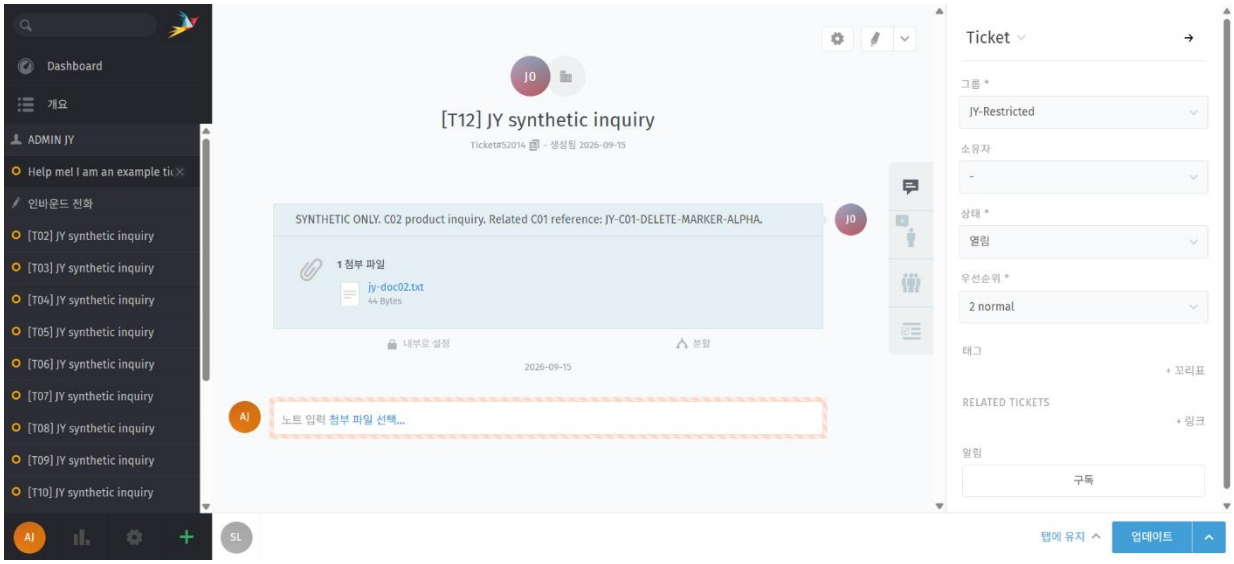
업무 영향: 발생 3, 영향 3, 점수 9, 우선. 잔여도 9점·우선이다. 백업 잔존은 미확인이라 그 범위에 별도 점수를 넣지 않는다.

적용 기준: 법 제21조 제1항·제2항. ISMS-P 3.4.1 참고. 인증심사가 아니다.

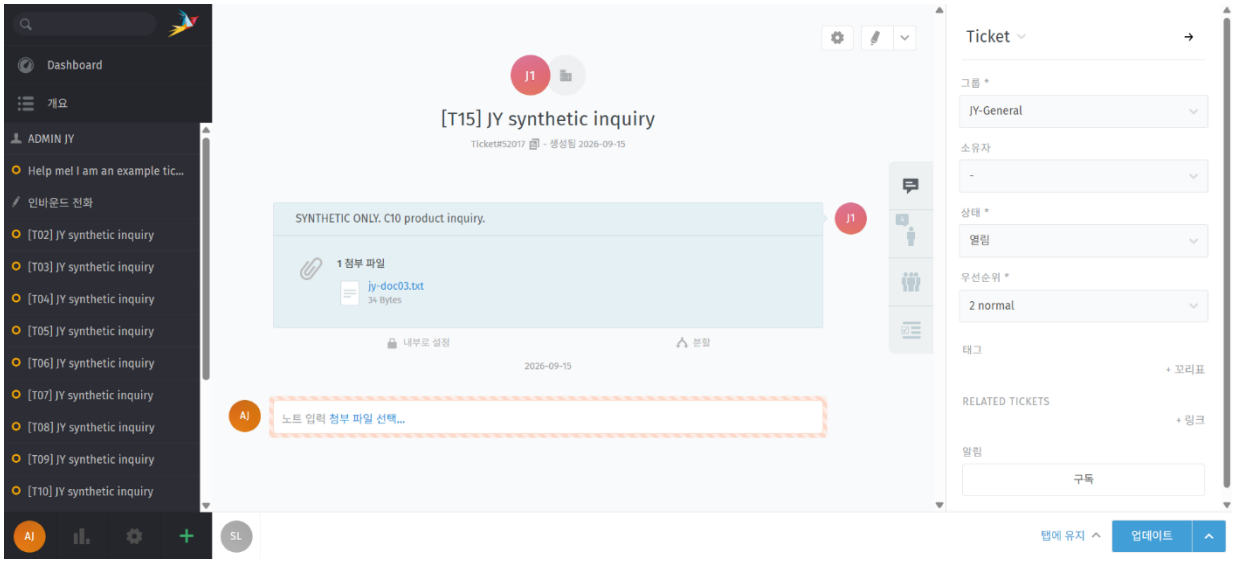
즉시조치: 본인 티켓 삭제까지. T12는 삭제하지 않았다.

근본조치: CR-04와 A-03은 2026-10-06 기한이 지났고 미완료다. 새 목표일과 다음 검토일은 2026-11-06이다. 담당은 S02, 실행은 S01이다. Scheduler 미리보기 1건 없이 T12를 삭제하지 않는다. 완료 화면은 다시 보지 않았다.

후 증적: E-F03-A01, E-F03-A02, E-D03-A01. E02의 증적ID는 E-F03-B01이다.



E-F03-A01. 공개 경로 evidence/sanitized/E-F03-A01.png. 관측 시각은 파일에 없다. F-03 조치 후 화면. 백업 잔존과 복구는 이 화면 밖이다.



E-F03-A02. 공개 경로 evidence/sanitized/E-F03-A02.png. 관측 시각은 파일에 없다. F-03 잔존 화면. 백업 잔존과 복구는 미확인이다.

정상업무 검증: 재점검 R-03 미흡. E02만 본인 티켓 삭제 범위에서 적합이다.

잔여위험: E03, D03, F04는 미흡이다. 백업은 미확인이다.

현재 상태: 본인 티켓 삭제는 확인. 참조와 사본은 증적으로 유지. 조직과 T15는 삭제하지 않았다.

16. 위험평가

가능성 1은 제한된 조건, 2는 일반 업무 실수, 3은 당시 재현이다. 영향 1은 제한된 업무정보, 2는 일부 고객 상담, 3은 다수 고객 또는 권리 침해 가능성이다. 곱은 1, 2, 3, 4, 6, 9만 나온다. 7부터 9는 우선, 4부터 6은 계획, 1부터 3은 관리다.

현재 위험은 F-01, F-02a, F-02b가 각 6점·계획이고 F-03이 9점·우선이다. 조치 후 잔여 중 발생이 미확인인 F-01, F-02a, F-02b에는 점수를 넣지 않는다. F-03 잔여는 9점·우선이다. Findings의 점수 3은 초기 등급

으로 남긴다.

17. 개선 Actions

조치	내용	실행일	상태	Checks에 남긴 값
A-01 / CR-01	S05 Active=false	2026-10-06	완료	C02 미흡
A-02a / CR-02	S04 General만, S06 그룹 없음	2026-10-06	완료	C03·D02 미흡
A-02b / CR-03	조직 공유=아니오	2026-10-06	완료	C04 미흡
A-03 / CR-04	T12 참조와 사본·백업	2026-10-06 기한 경과	미완료. 새 목표일 2026-11-06. 담당 S02, 실행 S01	E03·D03 미흡

CR-01부터 CR-03은 롤백하지 않았다. 비용은 없다.

문서 보완으로 처리방침 개선본, 수탁 점검표, 교육 1장, 도상훈련, 권리 요청 모의 기록 RR-01을 두었다. 이 문서들은 해당 Checks를 적합으로 바꾸지 않는다.

18. 재점검

R-01, R-02a, R-02b는 적합이다. R-03은 미흡이다.

재점검은 조치 이후의 확인이다. Checks는 처음 발견을 유지한다. E02의 적합은 E03과 D03의 미흡을 덮지 않는다.

19. 잔여위험·예외·미확인

항목	상태	내용
EX-01 / E04	미확인	백업 복구 실측 안 함
EX-02 / C02	미흡	기존 Sessions 회수 미확인
EX-03 / T12	미흡	마커 증적 유지. 미리보기 전 삭제 금지
EX-05 / D03	미흡	jy-doc02-copy.txt 잔존. Git 제외
EX-06 / B04	미확인	실제 권리 메일 없음. RR-01은 모의 기록
EX-07 / F03	적용 제외	외부 AI 미연결
F02	미흡	사고 양식과 실제 신고 없음
D01	미흡	수탁 연간 실적 없음

D04	미흡	교육 서명 없음
E01	미흡	보유기간 문구가 모호

Incident 시트에는 INC-01 네 행이 있다. 실제 시각과 모의 경과를 구분했다. 실제 신고와 통지는 하지 않았다.

20. 30/90일 계획

기준 문서는 docs/15-30-90-plan.md다. 기준일은 2026-10-07이다.

30일 안에 문서로 둔 항목은 처리방침 개선본, 수탁 점검표, 교육 1장, 도상훈련, 권리 절차 초안이다. 그 뒤 RR-01 모의 기록을 추가했다. T12 삭제는 30일 안에 강제하지 않는다.

90일 항목인 백업 범위 결정, 수탁 재확인, 종료 계정 반복 점검, 사본 검색 절차, Sessions 확인은 미실시다. P90-07의 Word와 PDF 제출본은 이 확장 본문을 만들기 전에는 없었다. 가이드 PDF를 그 제출본으로 쓰지 않는다.

21. 수행 한계

수행자가 두 역할을 겸했다. 실제 법무 검토, 실제 교육 출석, 실제 수탁 감독, 실제 권리 회신은 없다.

ISO 본문은 보지 않았다. KISA 상세가이드의 기술 항목은 수행하지 않았다. ISMS-P 인증 충족으로 쓰지 않는다. 고시 제4조는 비워 둔다.

2026-10-19에는 Docker Desktop 엔진이 중지되어 Zammad 이미지 태그를 다시 읽지 못했다. 2026-10-08과 2026-10-14의 이미지 기록을 그날의 값으로 남긴다.

Gitleaks는 설치되어 있지 않다. 비밀 검사는 추적 파일에 대한 수동 검색으로 남겼고, 토큰 값은 커밋하지 않았다.

22. 출처 색인

ID	문서	상태
S-L01	개인정보 보호법 제21445호	시행 2026-09-11. 확인 2026-10-14
S-L02	시행령 제36671호	시행 2026-09-11. 확인 2026-10-14
S-L03	안전성 확보조치 기준 고시 제2026-9호	시행 2026-07-01. 확인 2026-10-14
S-L04	처리방침 작성지침 2026.4.	작성지침. 시행일 없음. 확인 2026-09-21
S-L05	ISMS-P 인증기준 안내서 (2023.11)	참고 연결. 인증심사 아님

S-L06	ISO/IEC 27701:2025	공개 서지정보. 본문 미확인
S-L07	KISA 주통기 기술 상세가이드	직접 기술 범위 아님

확인일과 시행일을 같은 날짜로 적지 않았다.

23. 증적 색인

공개 보고서에는 증적 ID와 보관 위치만 적는다. 원본 PNG와 JSON은 C:₩JY-Lab₩private-evidence₩에만 둔다. 해시 원문은 이 본문에 다시 옮기지 않는다. 2026-10-07 마무리 검토에는 JSON-F01-DIFF와 E-D03-A01 해시가 워크북에 기입되어 있다고 적혀 있다. ENV 해시는 그때 공란 유지가 허용되었고, 2026-10-19에 그 칸을 다시 열지 않았다.

ID	내용
E-F01-B01, E-F01-A01, JSON-F01-DIFF	F-01 전후. S05 active 변경
E-F02-B01~B03, E-F02-A01, A01b, A02, A03	F-02 전후
E-F03-B01~B03, E-F03-A01, A02	F-03. E02는 E-F03-B01
E-D03-A01	로컬 사본 잔존
docs/scope.md.txt, docs/data-flow.pdf, docs/interview.md.txt	A01, A03, A04
docs/15-rights-request-simulation.md	RR-01. B04는 미확인 유지

24. Git/CI/Release 검증

항목	2026-10-19 상태
작업 브랜치	docs/closeout-deliverables-02
이 보고서 확장 전 푸시	949a0bd
main	35b7b85. 태그 v1.0-final
이미 main에 병합된 풀 리퀘스트	#3부터 #7
이 보완 브랜치의 Pull Request	없음
이 보완 브랜치의 CI	이 문서에서 확인하지 않음
Release v1.0-final.1	없음
Drive 제출 패키지	없음
강제 머지	하지 않음

다음 순서는 이 본문을 저장한 뒤 Word와 PDF를 만드는 것이다. 그 전에 이 브랜치를 main에 머지하지 않는다.

공개 PNG가 없는 증적ID: E-F02-B02, E-F02-A01b, E-F03-B02, E-F03-B03, E-D03-A01. 원본은 C:₩JY-Lab₩private-evidence₩ 에만 둔다.